

CTF Writeup: SPAN Sniff

Challenge Name: SPAN Sniff

Category: Network Forensics

Flag: SK-CERT{h1DD3n_1n_pl41n7eX7_n37Fl0w}

1. Challenge Overview

The challenge provides a PCAP file (network.pcap) containing a packet capture from a mirrored SPAN port. The goal is to identify a covert channel used by an attacker to exfiltrate or hide data within standard HTTP traffic.

2. Network Inventory

Analysis of the traffic reveals three primary participants:

- 192.168.1.69:** The internal client making frequent HTTP requests.
- 10.10.10.10:** The web server responding to requests on port 8080.
- 192.168.48.134:** A secondary host engaged in SSH and HTTPS traffic (Decoy).

3. Initial Analysis & Rabbit Holes

Initial inspection of the HTTP payloads showed several "suspicious" fields that turned out to be decoys:

- JSON Fields:** Fields like `processing_time`, `execution_time`, and `score` contained varying numeric values but did not translate to a flag.
- JWT Tokens:** Long Base62-style strings in the login responses were found to be 128-character fillers.
- SSH Traffic:** Outbound SSH connections to a server named "conker" were investigated but yielded no actionable data.

4. The Covert Channel: HTTP Version Switching

The breakthrough occurs when examining the HTTP Version field of the client's requests. While the server always responds with HTTP/1.0, the client (192.168.1.69) inconsistently switches between HTTP/1.0 and HTTP/1.1 for its requests. This is a binary covert channel where the version field acts as a bitstream:

- HTTP/1.0:** Binary 0
- HTTP/1.1:** Binary 1

5. Step-by-Step Extraction

Filter and Observation

By filtering for client requests (`http.request` and `ip.src == 192.168.1.69`), a pattern emerges in the first 8 requests:

Request	Version	Bit Value
Req 1	1.0	0
Req 2	1.1	1
Req 3	1.0	0
Req 4	1.1	1

Req 5	1.0	0
Req 6	1.0	0
Req 7	1.1	1
Req 8	1.1	1

Binary Result: 01010011 → **ASCII:** S

Automated Extraction

To retrieve the full data, use `tshark` to extract the version bits from all requests:

```
tshark -r network.pcap -Y "http.request" -T fields -e http.request.version | sed 's/HTTP\1.0/' | tr -d '\n'
```

6. Final Flag

The resulting 296 bits (37 bytes) decode directly into the flag:

SK-CERT{h1DD3n_1n_pl41n7eX7_n37Fl0w}